Company Name: HealthPay Dynamics
Industry: Healthcare IT and Revenue Cycle Management

HealthPay Dynamics provides billing and patient portal software for small size hospital networks. They handle both highly sensitive patient medical records and high volumes of credit card transactions for patient copays and billing. HealthPay Dynamics is a Software-as-a-Service (SaaS) provider focused entirely on the mid-market healthcare sector. Their primary clients are regional hospital networks, specialized outpatient clinic groups, and urgent care franchises

Company Size: Approximately 350 employees, including a large software development team, customer support, IT operations, and a small, stretched-thin compliance and security team.
System Volume: Their platform currently processes over 2 million patient logins per month and handles upwards of $500 million in patient payment transactions annually.

Core Product Suite (Where the Data Lives)
HealthPay Dynamics offers two primary, interconnected software modules, each carrying distinct regulatory burdens:

1. **CareConnect** Patient Portal - A web and mobile application where patients log in to view lab results, read doctor's notes, manage prescriptions, and securely message their care teams.
   Compliance Focus - Heavily regulated by **HIPAA** because it stores, transmits, and displays highly sensitive electronic Protected Health Information (ePHI)
2. **RevenueStream** Billing Gateway - A backend financial engine that integrates with the hospitals' internal systems to generate patient invoices, process insurance claims, and accept credit card payments for copays and out-of-pocket costs.
   Compliance Focus - Strictly regulated by **PCI-DSS** because it captures, processes, and transmits credit card Primary Account Numbers (PAN) and authentication data.

To serve multiple hospital networks, HealthPay Dynamics uses a cloud-hosted infrastructure.

Since their servers, databases, and APIs are constantly communicating over the internet, they adopted the **NIST Cybersecurity Framework (NIST CSF)** to manage their overall cyber risk, ensuring they have proper firewalls, encryption, and access controls in place.

The Problem: Traditional Compliance Monitoring

Currently, HealthPay Dynamics manages its complex regulatory requirements using outdated, traditional methods. They rely heavily on manual processes, spreadsheets, and periodic audits to track compliance. Despite building modern software for hospitals, HealthPay Dynamics' internal compliance management is stuck in the past. Because they must adhere to HIPAA, PCI-DSS, and the NIST Cybersecurity Framework, their regulatory burden is heavy, but their tools for managing it are primitive.

Breakdown of their outdated approach:

1. They have one workbook for HIPAA requirements, a completely separate one for PCI-DSS controls, and another for NIST CSF – this results in isolated tracking
2. Many controls overlap e.g. all three frameworks require strict password policies and access controls. However, because the spreadsheets don't talk to each other, the team manually enters the exact same evidence three different times in three different places.
3. Spreadsheets are constantly emailed back and forth between the IT department, HR, and the compliance officer. This frequently leads to broken formulas, overwritten data, and confusion over which document is the live version, resulting in heavily fragmented data.

In HealthPay Dynamics, proving that security control is working is an entirely manual, human-driven process.

- Screenshot Compliance - When an audit approaches, the IT team must spend hours taking manual screenshots of server configurations, firewall rules, and Active Directory user lists.
- Disconnected Storage - These screenshots and log files are saved as PDFs and dumped into complex, nested folders on a shared network drive. There is no direct link between the policy written in the spreadsheet and the actual technical evidence sitting in the folder.
- Human Error - Because tracking relies on human memory and manual data entry, critical tasks like documenting the quarterly review of user access privileges are frequently forgotten until an auditor asks for them.

Compliance Spreadsheets for HealthPay Dynamics

Because of these manual methods, the company suffers from fragmented data, limited visibility, and delayed identification of compliance gaps. Here is what that looks like in practice:

- **Gap 1: Disconnected Evidence (PCI-DSS & NIST CSF)** * *The Issue:* To satisfy PCI-DSS and NIST CSF, the company must perform quarterly vulnerability scans and patch critical systems within 30 days. The IT team performs the patches, but the evidence (log files) isn't linked to the compliance spreadsheet.
    - *The Result:* During an audit, the compliance manager spends weeks manually hunting down emails and log files to prove the controls were met, demonstrating severe data fragmentation.

A1 | fx Asset ID

	A	B	C	D	E	F	G	H
1	Asset ID	System Role	Q1 Scan Date	Vuln Severity	30-Day Patch Deadline	Patch Applied Date	Evidence Location (The Gap)	Auditor Notes
2	WEB-01	Patient Portal	01/10/2026	Critical	02/09/2026	02/01/2026	C:\Users\DaveM\Desktop\logs\patch1.pdf	Need Dave's laptop to verify.
3	WEB-02	Billing Gateway	01/10/2026	High	02/09/2026	02/08/2026	Emailed to Sarah on 2/9.	Sarah deleted the email. Need to re-pull logs.
4	DB-East	PHI Database	01/12/2026	Critical	02/11/2026	02/10/2026	Z:\Shared\IT\Scans\Temp\db_log.txt	File is corrupted/unreadable.
5	AUTH-01	User Auth	01/12/2026	High	02/11/2026	02/15/2026	Ask Kevin.	Patch was late. Kevin says he has proof of extension, can't find it.
6	PAY-01	PCI Processing	01/15/2026	Critical	02/14/2026	02/10/2026	Printed copy on Mike's desk.	Mike is on PTO.
7	PAY-02	PCI Processing	01/15/2026	High	02/14/2026	02/12/2026	#REF! (Link Broken)	Spreadsheet formula broke. Evidence lost.
8	API-Ext	External API	01/18/2026	Critical	02/17/2026	02/16/2026	Attached to JIRA ticket #4092.	Compliance team doesn't have JIRA access.
9	RPT-01	Reporting	01/18/2026	Medium	N/A	03/01/2026	None	Deemed low risk, but auditor wants proof of risk acceptance.
10	APP-03	Mobile Backend	01/20/2026	High	02/19/2026	02/19/2026	Slack message from Dev team	Slack history deleted after 30 days. No proof.
11	APP-04	Mobile Backend	01/20/2026	Critical	02/19/2026	02/25/2026	C:\Downloads\patch_success.png	Late patch. Screenshot on a local machine.
12	NET-FW1	Main Firewall	01/22/2026	High	02/21/2026	02/20/2026	Vendor portal dashboard.	Password to vendor portal is lost.
13	NET-FW2	Backup Firewall	01/22/2026	High	02/21/2026	02/20/2026	Vendor portal dashboard.	Same as above.
14	STOR-01	Backup Storage	01/25/2026	Critical	02/24/2026	02/20/2026	Texted screenshot to CISO.	Not an acceptable form of audit evidence.
15	MAIL-01	Exchange Serve	01/28/2026	Critical	02/27/2026	02/26/2026	\\Nas-Drive\IT\old\scans\mail.log	Nas-Drive was decommissioned in March.
16	INT-Wiki	Confluence	01/28/2026	High	02/27/2026	02/20/2026	"Completed"	No evidence attached at all.
17								

- **Gap 2: Delayed Access Revocation (HIPAA)**
    - *The Issue:* When an employee leaves, HR updates a spreadsheet, but the notification to IT to revoke access to the patient database is often delayed.
    - *The Result:* Because there is no real-time mapping of controls to evidence, ex-employees sometimes retain access to Patient Health Information (PHI) for days after termination. This delayed identification of a compliance gap is a massive HIPAA violation.

A1 | Employee Name

	A	B	C	D	E	F	G	H
1	Employee Name	Department	Termination Date	HR Sheet Updated	IT Notified Date	PHI Database Access Revoked	Gap (Days with Unauthorized Access)	Status / Notes
2	Smith, John	Billing	02/01/2026	02/01/2026	02/04/2026	02/06/2026	5 Days	IT missed the email. HIPAA Violation.
3	Doe, Jane	Clinical	02/05/2026	02/06/2026	02/06/2026	02/06/2026	0 Days	Compliant.
4	Lee, Amanda	Dev Ops	02/10/2026	02/10/2026	02/25/2026	02/26/2026	16 Days	HR forgot to notify IT. Major HIPAA Violation.
5	Torres, M.	Finance	02/12/2026	02/12/2026	02/12/2026	02/18/2026	6 Days	IT ticket sat in queue unassigned.
6	Jenkins, R.	Support	02/15/2026	02/15/2026	02/16/2026	02/16/2026	1 Day	Acceptable delay.
7	Patel, S.	Clinical	02/20/2026	02/22/2026	03/01/2026	03/05/2026	13 Days	Weekend termination. Paperwork delayed.
8	Gomez, L.	IT Admin	02/25/2026	02/25/2026	02/25/2026	03/10/2026	13 Days	Manager forgot they had secondary admin accounts.
9	White, K.	Billing	03/01/2026	03/01/2026	No Record	No Record	UNKNOWN	K. White may still have active access today.
10	Barnes, T.	HR	03/05/2026	03/06/2026	03/06/2026	03/06/2026	0 Days	Compliant.
11	Nguyen, P.	Support	03/10/2026	03/10/2026	03/15/2026	03/16/2026	6 Days	IT helpdesk was understaffed that week.
12	Kim, Chloe	Marketing	03/12/2026	03/12/2026	03/12/2026	04/01/2026	20 Days	Revoked from email, but forgot to revoke PHI dashboard.
13	Davis, R.	Clinical	03/18/2026	03/19/2026	03/19/2026	03/25/2026	6 Days	Account left active so replacement could view history. (Violation)
14	Evans, B.	Finance	03/20/2026	03/20/2026	04/05/2026	04/05/2026	16 Days	Notification sent to wrong IT email alias.
15	Carter, J.	Support	03/25/2026	03/25/2026	03/25/2026	03/26/2026	1 Day	Compliant.
16	Miller, A.	Dev Ops	03/28/2026	03/30/2026	Pending	Pending	ACTIVE	Employee left 2 weeks ago; DB access still completely active.
17								
18								

- **Gap 3: Executive Blind Spots**
    - *The Issue:* The Chief Information Security Officer (CISO) only receives a static compliance report after the annual internal audit.
    - *The Result:* It is extremely difficult for leadership to understand the organization's real-time compliance status and associated risks. If a server falls out of PCI compliance in March, the CISO might not know until the December audit

	A	B	C	D	E	F	G	H
1	Framework	Control ID	Requirement Description	Last Audit Date	Status at Audit	True Date of Control Failure	Date CISO Notified	Executive Blind Spot Duration
2	PCI-DSS	Req 1.1.6	Review firewall and router rule sets every 6 months.	12/01/2024	Compliant	06/01/2025	12/05/2025	6 Months - Reviews stopped in June.
3	HIPAA	164.308	Security Awareness Training for all new hires.	12/01/2024	Compliant	02/15/2025	12/05/2025	10 Months - HR stopped assigning module in Feb.
4	NIST CSF	PR.AC-1	Identities and credentials are managed.	12/01/2024	Compliant	03/10/2025	12/05/2025	9 Months - Ghost accounts accumulating since March.
5	PCI-DSS	Req 8.3.1	MFA required for all administrative access.	12/01/2024	Compliant	04/20/2025	12/05/2025	8 Months - API update broke MFA; IT bypassed it.
6	HIPAA	164.312	Encrypt ePHI at rest.	12/01/2024	Compliant	08/12/2025	12/05/2025	4 Months - New backup server deployed without encryption.
7	NIST CSF	DE.CM-1	Network is monitored to detect cyber events.	12/01/2024	Compliant	01/05/2025	12/05/2025	11 Months - Intrusion Detection System license expired in Jan.
8	PCI-DSS	Req 11.2	Run internal vulnerability scans quarterly.	12/01/2024	Compliant	07/01/2025	12/05/2025	5 Months - Q3 and Q4 scans were never performed.
9	HIPAA	164.308	Business Associate Agreements (BAAs) maintained.	12/01/2024	Compliant	05/10/2025	12/05/2025	7 Months - New vendor hired in May without a BAA.
10	NIST CSF	PR.DS-5	Data leak protection is implemented.	12/01/2024	Compliant	02/28/2025	12/05/2025	9 Months - DLP software crashed and was turned off.
11	PCI-DSS	Req 6.4.3	Manage payment page scripts (e-skimming protection	12/01/2024	Compliant	09/15/2025	12/05/2025	3 Months - Marketing added unvetted tracking script.
12	HIPAA	164.312	Automatic logoff after inactivity.	12/01/2024	Compliant	10/01/2025	12/05/2025	2 Months - Feature disabled by dev team for "convenience."
13	NIST CSF	PR.IP-3	Configuration baseline is maintained.	12/01/2024	Compliant	03/15/2025	12/05/2025	9 Months - Unauthorized ports opened on production servers.
14	PCI-DSS	Req 3.4.1	Render PAN unreadable anywhere it is stored.	12/01/2024	Compliant	11/02/2025	12/05/2025	1 Month - Error logs started printing raw credit card numbers.
15	HIPAA	164.308	Facility security plan / physical access control.	12/01/2024	Compliant	04/01/2025	12/05/2025	8 Months - Server room badge reader broke in April.
16	NIST CSF	RS.CO-2	Incidents are reported to stakeholders.	12/01/2024	Compliant	07/20/2025	12/05/2025	5 Months - Minor breach occurred in July, CISO never told.
17								
18								
19								
20								
21								

Why the Compliance Monitoring Tool is the Ultimate Solution for HealthPay Dynamics **Gemini said**

Here is an expanded, highly detailed justification of **Why Your Tool is the Solution**.

This expansion directly connects the disastrous fictional spreadsheets we just created to the specific technical deliverables outlined in your capstone project's Work Breakdown Structure (WBS), particularly the **Control-to-Evidence Relationship Model** and the **Executive Dashboard**.

You can use this text directly in your project report's "Proposed Solution" or "Business Case" section.

Why the Compliance Monitoring Tool is the Ultimate Solution for HealthPay Dynamics

HealthPay Dynamics is currently drowning in spreadsheet compliance. Their reliance on fragmented, manual data entry has created a high-risk environment where critical vulnerabilities are ignored, ex-employees retain access to sensitive medical records (PHI), and executive leadership is operating completely in the dark.

The proposed Compliance Monitoring and Reporting Tool fundamentally transform how the organization handles regulatory requirements by moving them from static, disconnected documents into a dynamic, centralized system.

Here is exactly how the tool solves HealthPay Dynamics' critical failures:

1. Solving Gap 1: Eradicating Disconnected Evidence

- The Spreadsheet Problem: Currently, IT patches a server for PCI-DSS compliance, but the log file proving the patch was applied is saved on a local laptop or lost in a deleted Slack message. The compliance manager cannot verify the control.
- The Tool's Solution (The Control-to-Evidence Relationship Model): Instead of manually typing "Evidence is on Dave's desktop" into a cell, your tool utilizes a Control-to-Evidence Relationship Model (WBS 1.3.1.1). Within the tool, every specific regulatory framework requirement is mapped as a relational database object directly tied to a specific evidence upload portal.

The Result: When IT patches the billing gateway, they upload the log directly into the tool. The tool instantly links that single piece of evidence to the overlapping NIST, HIPAA, and PCI-DSS controls it satisfies. The auditor clicks one button to see the policy, the system asset, and the proof eliminating weeks of manual evidence hunting.

2. Solving Gap 2: Automating Workflows to Prevent HIPAA Violations

- The Spreadsheet Problem - HR marks an employee as terminated on a spreadsheet, but IT doesn't see it for 16 days. The ex-employee retains active access to the Patient Health Information (PHI) database, resulting in a severe HIPAA violation.
- The Tool's Solution (Automated Reporting & Tracking Logic) - Your tool introduces real-time state tracking rather than static text entry. Using Automated Reporting Logic (WBS 1.3.1.5), the tool tracks the lifecycle of a compliance task.

The Result*:* The moment HR logs a termination, the tool generates an active ticket tied to the HIPAA "Access Revocation" control. If IT does not upload evidence of revoked database access within the mandated 24-hour window, the tool automatically flags the control as "FAILED" and triggers an alert. It enforces the policy rather than just recording it after the fact.

3. Solving Gap 3: Eliminating Executive Blind Spots

- The Spreadsheet Problem - The CISO relies on a "Master Matrix" Excel file that is only updated during the December audit. If a critical intrusion detection system fails in January, the CISO is completely blind to that risk for 11 months.
- The Tool's Solution (The Executive Dashboard & Risk Level Metadata) - The crown jewel of your solution is the Executive Dashboard (WBS 1.3.1.3), powered by Risk Level Metadata Architecture (WBS 1.3.1.2). The tool continuously aggregates the status of all underlying controls (patches, training, access reviews) and translates them into real-time visual metrics.

The Result***:*** The CISO no longer waits for an annual report. When they log in on a Tuesday in March, they see a live gauge. If a production server falls out of PCI compliance, the dashboard instantly flashes red for "Payment Gateway Risk."

Our tool implements **Role-Based Access Control (RBAC) Logic** (WBS 1.3.1.4) to solve this communication breakdown.

- **The IT Team** sees a technical view: a simple list of missing patches and overdue access reviews they need to complete.
- **The CISO and Executive Board** see a business-risk view: aggregated pie charts, overall HIPAA readiness scores, and high-level financial risk warnings.

SO US WE ARE GOING TO ACT AS THE BRIDGE BETWEEN THE TECHNICAL AND NON TECHNICAL PEOPLE